



FFIEC Information Technology Examination Handbook

Management

NOVEMBER 2015

Contents

INTRODUCTION	3
I GOVERNANCE.....	4
I.A IT Governance	4
I.A.1 Board of Directors Oversight	4
I.A.2 IT Management	6
I.A.3 Enterprise Architecture	9
I.B IT Responsibilities and Functions	10
I.B.1 IT Risk Management Structure.....	10
I.B.2 Information Security	10
I.B.3 Project Management	11
I.B.4 Business Continuity.....	12
I.B.5 Information Systems Reporting	12
I.B.6 Planning IT Operations and Investment	14
I.B.7 Other Functions.....	18
II RISK MANAGEMENT	20
II.A Operational Risk.....	20
III IT RISK MANAGEMENT	21
III.A Risk Identification	22
III.A.1 Ongoing Data Collection	22
III.B Risk Measurement	24
III.C Risk Mitigation.....	26
III.C.1 Policies, Standards, and Procedures	27
III.C.2 Personnel.....	27
III.C.3 Information Security	28
III.C.4 Business Continuity.....	30
III.C.5 Software Development and Acquisition.....	31
III.C.6 IT Operations	31
III.C.7 Insurance	32
III.C.8 Third-Party Management	34
III.D Monitoring and Reporting	36

III.D.1	Metrics	36
III.D.2	Performance Benchmarks.....	37
III.D.3	Service Level Agreements	37
III.D.4	Policy Compliance.....	37
III.D.5	Effectiveness of Controls	38
III.D.6	Quality Assurance and Quality Control	38
III.D.7	Reporting	38
APPENDIX A: EXAMINATION PROCEDURES		40
APPENDIX B: GLOSSARY		57
APPENDIX C: REFERENCES		63

Introduction

The “Management” booklet is one of 11 booklets that make up the *Federal Financial Institutions Examination Council (FFIEC) Information Technology Examination Handbook (IT Handbook)*. The “Management” booklet rescinds and replaces the June 2004 version. This booklet provides guidance to examiners and outlines the principles of overall governance and, more specifically, IT governance. Additionally, this booklet explains how risk management is a component of governance and how IT risk management (ITRM) is a component of risk management. This booklet describes the interaction of these components. The examination procedures in this booklet assist examiners in evaluating the following:

- IT governance as part of overall governance in financial institutions.
- Processes for ITRM as part of risk management in financial institutions.¹

IT supports most aspects of a financial institution’s business; therefore, effective ITRM is not limited to technology. The IT department typically manages back-office operations, network administration, and systems development and acquisition, and is involved in business continuity and resilience, and third-party management. IT management provides expertise in choosing and operating technology solutions for an institution’s lines of business (e.g., commercial credit and asset management) or for enterprise-wide activities (e.g., security and business continuity planning).

IT management is critical to the performance and success of a financial institution. ITRM involves more than containing costs and controlling operational risks and does not work in isolation. A financial institution capable of aligning its IT infrastructure to support its business strategy adds value to the institution and positions itself for sustained success. Financial institutions face many challenges in today’s marketplace, including cybersecurity threats, increasing the need for effective IT management and ITRM.

An institution’s IT systems may connect with affiliates, customers, internal lines of business, third parties (e.g., third-party providers²), and the public. IT creates interdependencies among infrastructure, applications, and Web content. These interdependencies affect the decision-making process necessary to support existing products and services and provide for the delivery of new products and services. Timely, accurate, and secure information is critical to meeting business requirements throughout the institution. Technology evolves rapidly, requiring enhancements to existing systems and prompting new investment in infrastructure, systems, and applications. New technology requires expertise, which creates competition for the necessary

¹ The term “financial institution” includes national banks, federal savings associations, state savings associations, state member banks, state nonmember banks, and credit unions, as well as technology service providers that provide services to such entities. The term is used interchangeably with “institution” in this booklet. This booklet may refer to technology service providers specifically in cases where the agencies do not mean to include financial institutions.

² Third-party providers, also called third-party service providers, include technology service providers or other third parties that perform critical business activities for or on behalf of an institution.

talent, knowledge, and skill sets. ITRM includes addressing new sources of risk that arise with new or evolving technology.

I Governance

Action Summary

Financial institution boards of directors should oversee, while senior management should implement, a governance structure that includes the following:

- Effective IT governance.
- Appropriate oversight of IT activities.
- Comprehensive IT management, including the various roles played by management.
- Effective enterprise architecture.

Governance refers to how financial institutions manage and control their institution. Governance provides the structure through which an institution sets and pursues objectives while taking into account the regulatory and market environment and culture of the institution. The governance structure specifies the responsibilities for the board of directors, managers, auditors, and other stakeholders and specifies the level of authority and accountability for decision making. Governance also includes mechanisms for monitoring actions and decisions enterprise-wide.

I.A IT Governance

IT governance is “an integral part of governance and consists of the leadership and organizational structures and processes that ensure that the organization’s IT sustains and extends the organization’s strategies and objectives.”³ IT governance objectives are to ensure that IT generates business value for the institution and to mitigate the risks posed by using technology.

I.A.1 Board of Directors Oversight

The board of directors sets the tone and direction for an institution’s use of IT. The board should approve the IT strategic plan, information security program, and other IT-related policies. To carry out their responsibilities, board members should understand IT activities and risks. The board or a board committee should perform the following:

- Review and approve an IT strategic plan that aligns with the overall business strategy and includes an information security strategy to protect the institution from ongoing and emerging threats, including those related to cybersecurity.

³ [*Board Briefing on IT Governance*](#), 2nd edition, IT Governance Institute, 2003.

- Promote effective IT governance.
- Oversee processes for approving the institution's third-party providers, including the third parties' financial condition, business resilience, and IT security posture.
- Oversee and receive updates on major IT projects, IT budgets, IT priorities, and overall IT performance. The board of directors may need to approve critical projects and activities, such as expanding the institution's product line to include mobile financial services.
- Oversee the adequacy and allocation of IT resources for funding and personnel.
- Approve policies to escalate and report significant security incidents to the board of directors, steering committee, government agencies, and law enforcement, as appropriate.
- Hold management accountable for identifying, measuring, and mitigating IT risks.
- Provide for independent, comprehensive, and effective audit coverage of IT controls.

The board may delegate the design, implementation, and monitoring of specific IT activities to management or a committee (e.g., IT steering committee). An IT steering committee⁴ generally comprises senior management and staff from the IT department and other business units. Committee members do not have to be department heads, but members should understand IT policies, standards, and procedures (collectively, policies⁵). Each member should have the authority to make and be held accountable for decisions within their respective business units. If the institution has a formal risk management function, risk management staff should participate in an advisory capacity.

The steering committee typically is responsible for reporting to the board on the status of IT activities. The reports enable the board to make decisions without having to be involved in routine activities. While the board may delegate the design, implementation, and monitoring of certain IT activities to the steering committee, the board remains responsible for overseeing IT activities and should provide a credible challenge⁶ to management. The steering committee is typically responsible for strategic IT planning, oversight of IT performance, and aligning IT with business needs. The steering committee should have a charter that defines its responsibilities.

The steering committee should receive appropriate information from IT, lines of business, and external sources. Additionally, it should coordinate and monitor the institution's IT resources. The steering committee should review and determine the adequacy of the institution's training, including cybersecurity training, for staff. The steering committee should also document meeting minutes and decisions and inform the board of directors of the committee's activities.

⁴ In smaller or less complex financial institutions that may not have steering committees, these functions would be performed by management, IT department personnel, the board, or a board committee.

⁵ For the purposes of this booklet, policies generally include policies, standards, and procedures, unless stated otherwise. When the booklet refers to policies and practices, it is the combination of the formal and approved policies, standards, and procedures and the actual practices in place.

⁶ A credible challenge involves being actively engaged, asking thoughtful questions, and exercising independent judgment.

I.A.2 IT Management

IT management is responsible for IT performance and administering the day-to-day operation of an institution. IT management should perform the following:

- Implement IT governance.
- Implement effective processes for ITRM, including those that relate to cybersecurity.
- Review and annually approve processes for ITRM.
- Assess the institution's inherent IT risks across the institution.
- Provide regular reports to the board on IT risks, IT strategies, and IT changes.
- Establish and coordinate priorities between the IT department and lines of business.
- Establish a formal process to obtain, analyze, and respond to information on threats and vulnerabilities⁷ by developing a repeatable threat intelligence and collaboration program.⁸
- Ensure that hiring and training practices are governed by appropriate policies to maintain competent and trained staff.

I.A.2(a) *Executive Management*

Executive management, including the chief executive officer (CEO), the chief operating officer (COO), and often the chief information officer (CIO), plays a significant role in IT management at a financial institution. Executive management develops the strategic plans and objectives for the institution and sets the budget for resources to achieve these objectives. To carry out its responsibilities, executive management should understand at a high level the IT risks faced by the institution and ensure that those risks are included in the institution's risk assessments. In the event that executive management is unable to implement an objective or agree on a course of action, executive management should escalate that matter to the board for more guidance.

I.A.2(b) *Chief Information Officer or Chief Technology Officer*

The CIO or chief technology officer (CTO) is responsible and should be held accountable for the development and implementation of the IT strategy to support the institution's business strategy in line with its risk appetite. In less complex institutions, the IT manager may take on these responsibilities. This position typically oversees the IT budget and maintains responsibility for performance management, IT acquisition oversight, professional development, and training. In addition, the CIO or CTO is responsible for implementing the IT architecture and participating in planning activities. The IT management reporting structure should enable this position to accomplish these activities and ensure accountability for security, business resilience, risk reporting, and alignment of IT with business needs. The CIO or CTO should play a key role in

⁷ See the [FFIEC's "Cybersecurity Threat and Vulnerability Monitoring and Sharing Statement,"](#) November 3, 2014.

⁸ For example, a repeatable threat intelligence and collaboration program could include internal resources, such as audit reports and fraud detection tools, or external resources, such as information sharing networks like the Financial Services–Information Sharing and Analysis Center (FS-ISAC) and the Federal Bureau of Investigation's (FBI) InfraGard.

the strategic planning as well as supporting activities of peers in various lines of business. The position often has a leadership role on the steering committee.

I.A.2(c) *Chief Information Security Officer*

The chief information security officer (CISO) is responsible for overseeing and reporting on the management and mitigation of information security risks across the institution and should be held accountable for the results of this oversight and reporting. Often, the CISO is responsible for implementing an information security program satisfying the Interagency Guidelines Establishing Information Security Standards⁹ (Information Security Standards), which were issued pursuant to the Gramm–Leach–Bliley Act (GLBA). While in the past the office of the CISO was considered a technology function, the role has become a strategic and integral part of the business management team. The CISO should be an enterprise-wide risk manager rather than a production resource devoted to IT operations.

To ensure independence, the CISO should report directly to the board, a board committee, or senior management and not IT operations management. While cost and benefit decisions will always need to be made, IT security decisions and funding should not be unduly influenced by operational ease or budgetary constraints. The reporting structure should demonstrate that the CISO has the appropriate authority to carry out the responsibilities of that position and should avoid conflicts of interest that could interfere with the ability of the CISO to make decisions in line with the board’s risk appetite. The institution’s size and complexity plays a role in the reporting structure. A smaller or less complex institution may have an information security officer perform the responsibilities of the CISO and report to senior management. A larger or more complex institution may have additional reporting lines for the CISO into other independent functions, such as risk management.

The CISO is typically responsible for the following:

- Implementing the information security strategy and objectives, as approved by the board of directors, including strategies to monitor and address current and emerging risks.
- Engaging with management in the lines of business to understand new initiatives, providing information on the inherent information security risk of these activities, and outlining ways to mitigate the risks.
- Working with management in the lines of business to understand the flows of information, the risks to that information, and the best ways to protect the information.
- Monitoring emerging risks and implementing mitigations.
- Informing the board, management, and staff of information security and cybersecurity risks and the role of staff in protecting information.
- Championing security awareness and training programs.

⁹ 12 CFR 30, appendix B (Office of the Comptroller of the Currency (OCC)); 12 CFR 208, appendix D-2 (Board of Governors of the Federal Reserve System); 12 CFR 364, appendix B (Federal Deposit Insurance Corporation (FDIC)); and 12 CFR 748, appendix A (National Credit Union Administration (NCUA)). Refer to [appendix C](#) of this booklet for a listing of laws, regulations, and agency guidance.

- Participating in industry collaborative efforts to monitor, share, and discuss emerging security threats.
- Reporting significant security events to the board, steering committee, government agencies, and law enforcement, as appropriate.

I.A.2(d) *IT Line Management*

IT line managers supervise the resources and activities of a specific IT function, department, or subsidiary. They typically coordinate services between the data processing area and other departments. They report to senior IT management on the plans, projects, and performance of their specific systems or departments. Some IT functions that often rely on line managers include data center operations, network services, application development, systems administration, telecommunications, customer support, and disaster recovery. Frontline managers coordinate daily activities, monitor current production, ensure adherence to established schedules, and enforce appropriate policies and controls in their areas.

I.A.2(e) *Business Unit Management*

Managers in an institution's lines of business or business units also have IT responsibilities. Examples of these responsibilities include the following:

- Establishing processes for ongoing communication of business needs, information systems reporting needs, and product development plans to IT support or line management.
- Ensuring that IT development efforts are prioritized, funded, and aligned with business strategy in the business unit.
- Establishing processes to test compliance with IT-related control policies in the business unit.
- Ensuring that required backup IT resources are available.
- Documenting information flows throughout the business unit and notifying the CISO when business processes change.
- Performing due diligence reviews for prospective third-party providers and ongoing monitoring of third-party providers with which the institution has established relationships.
- Engaging with the CISO to discuss inherent information security risks of new business unit initiatives.

The specific technology roles in IT and business unit management may vary depending on the institution's approach to risk management and policy enforcement. Institutions can approach technology management using either a centralized or a decentralized strategy.

In a centralized IT environment, IT management typically acquires, installs, and maintains technology for the entire institution. IT management has a greater ability to control and monitor the institution's technology investment. A centralized approach may promote greater operational efficiencies. The business unit managers retain the responsibility for enforcing internal controls within their areas.

In a decentralized IT environment, IT management serves in an advisory role in some business units' acquisition, installation, and maintenance of technology. The decentralized approach is

more common in larger or more complex institutions, where IT management can expedite decisions on IT services by transferring decision-making authority to strategically significant departments. In this approach, business line management has a much greater responsibility for ensuring that technology investments are consistent with enterprise-wide strategic plans. Institutions should ensure system compatibility and enforcement of enterprise-wide policies in a decentralized environment. IT management should still have a role in defining the institution's control requirements, but enforcement of enterprise-wide policies may be more difficult.

I.A.3 Enterprise Architecture

Enterprise architecture (EA) is the overall design and high-level plan that describes an institution's operational framework and includes the institution's mission, stakeholders, business and customers, work flow and processes, data processing, access, security, and availability. An EA program facilitates the conceptual design and maintenance of the network infrastructure, related IT controls, and policies. Management of financial institutions with highly complex systems or those experiencing growing IT costs without corresponding benefits should consider using or adjusting an EA program. As EA has evolved, different methodologies to implement EA programs have been developed. The underlying principle for all EA programs is that business IT requirements follow a predefined process that begins with a business need and ends with an IT solution that conforms to the policies approved by senior management and the board of directors. An effective EA program can result in the following:

- Enhanced interoperability from using IT to drive business adaptability.
- Closer partnership between business and IT groups.
- Improved focus on the institution's goals.
- Reduced numbers of failed IT systems.
- Reduced complexity of IT systems.
- Improved agility of IT systems.
- Closer alignment between IT deliverables and business requirements.
- Assurance that all software, including operating systems, is current and vendor supported.
- Improved morale, as more staff members see a direct correlation between their work and the institution's success.

Key considerations when developing an EA program include security, business resilience, data management, external connectivity, and alignment with the institution's goals and objectives. To effectively implement an EA program, the institution should analyze the risks and potential impact of threats to all of the institution's activities. A comprehensive EA program based on prudent practices can help an institution better develop processes to manage IT issues and identify, measure, and mitigate technology-based risks and threats.